ICT2142 E-Business Systems

Lecture 09

E-Business Security & Legal Aspects



Department of ICT
Faculty of Technology
University of Ruhuna

Learning Outcomes

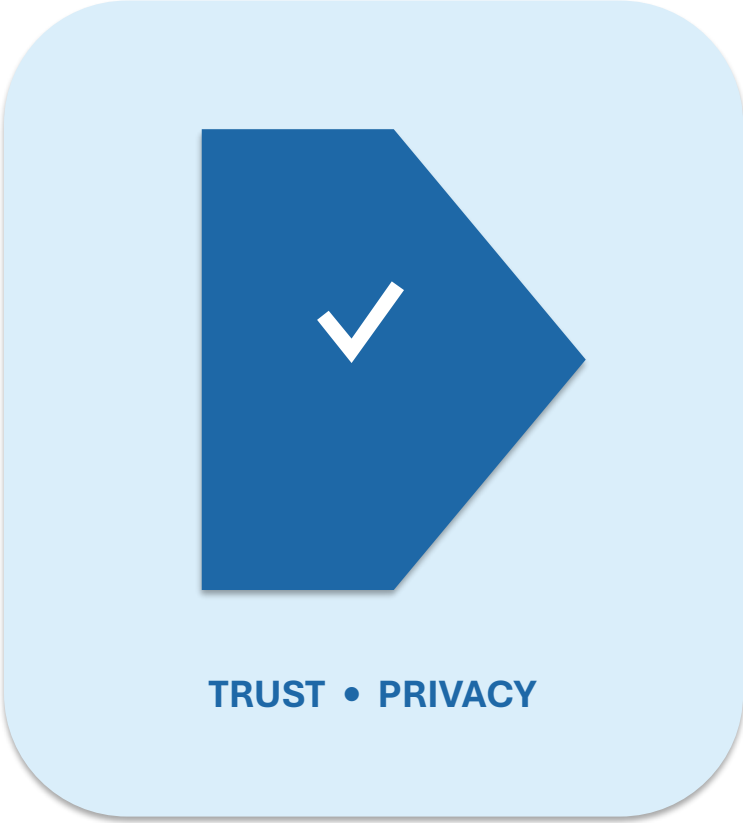
- **Explain key threats**
  Recognize phishing, DDoS, account takeover, payment fraud and data breaches.
- **Recommend safeguards**
  Distinguish customer-side, browser-side, application and server controls.
- **Use frameworks**
  Map e-commerce risks to cybersecurity governance and operational controls.
- **Assess compliance**
  Identify privacy principles and local/global legal responsibilities.



TRUST • PRIVACY

Why security matters in e-business

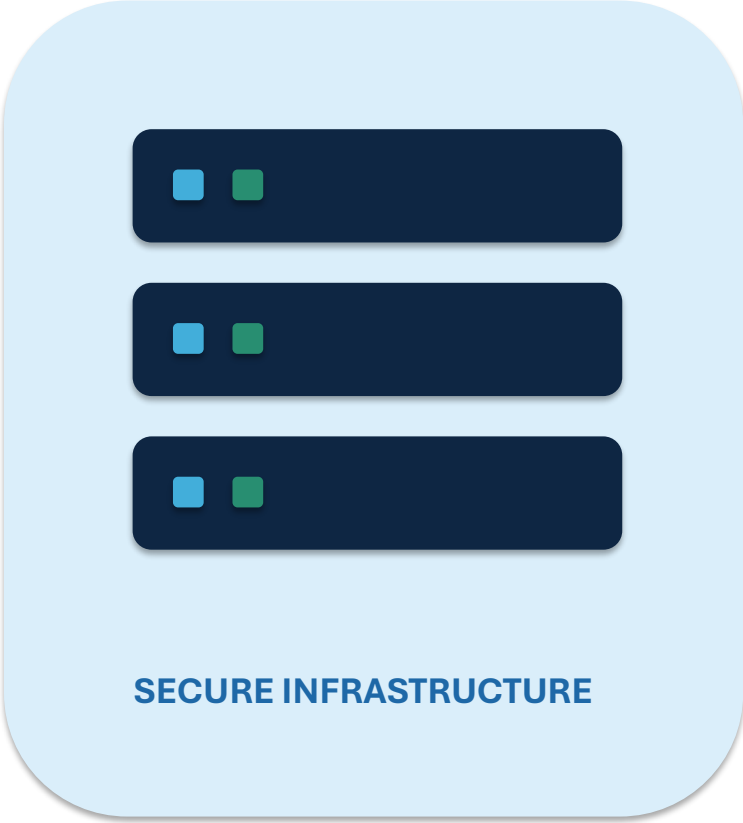
- **Customer confidence**
  Buyers expect secure payments, private accounts and reliable order fulfilment.
- **Business continuity**
  Service disruption can prevent browsing, checkout and order processing.
- **Financial and reputational impact**
  Fraud, breach response and loss of trust can damage the business.
- **Legal responsibility**
  Organizations must consider privacy, consumer and payment-related obligations.



The e-commerce attack surface

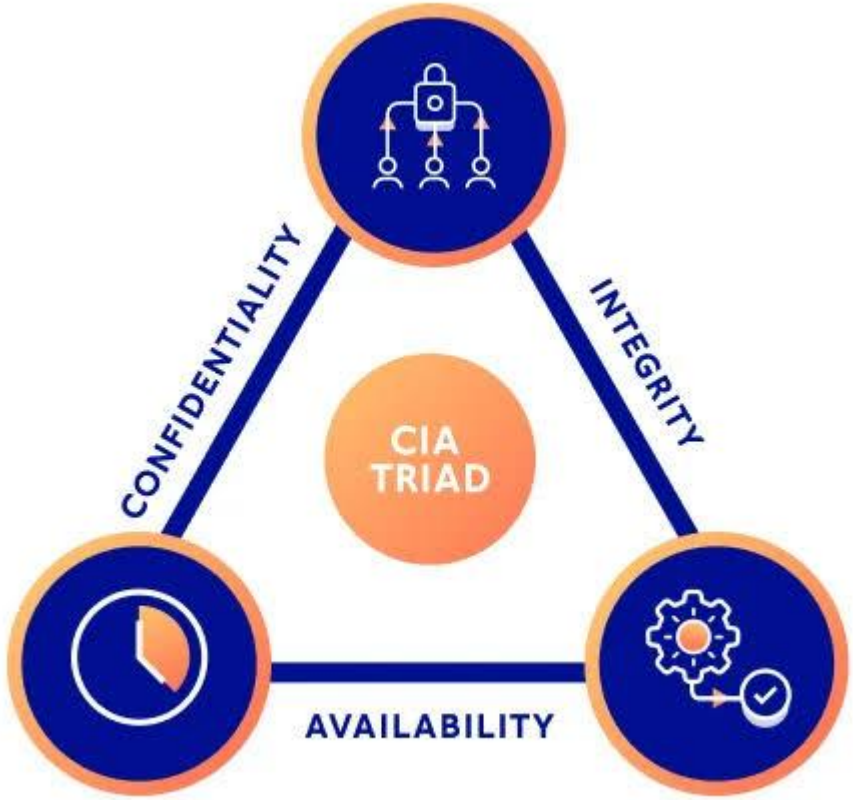
Multiple connected components create multiple opportunities for failure.

- **Customer touchpoints**
  Browsers, mobile apps, emails, SMS messages and login flows.
- **Application services**
  Product catalogue, shopping cart, checkout, APIs and admin portal.
- **Infrastructure and suppliers**
  Cloud hosting, DNS, payment gateway, logistics and third-party scripts.
- **Data assets**
  Customer identity, addresses, orders, tokens and transaction records.



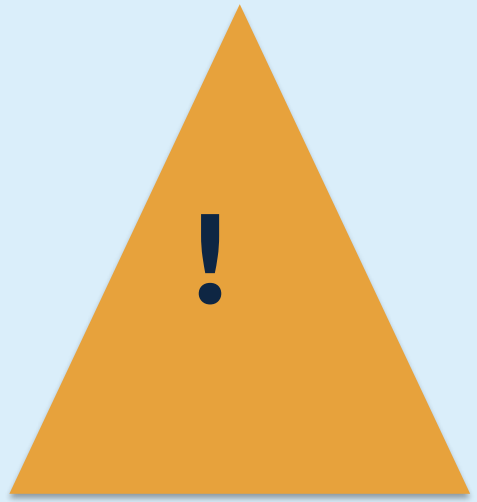
Security Objectives: the CIA triad

- **Confidentiality**
  Prevent unauthorized access to customer information and payment-related data.
- **Integrity**
  Ensure order totals, inventory, product prices and transactions are accurate.
- **Availability**
  Keep browsing, login, payment and fulfilment services accessible.
- **Additional assurance**
  Authentication, authorization, accountability and non-repudiation also matter.



Common security risks

- **Phishing and social engineering**
  Deceptive messages or websites trick customers or employees into sharing information.
- **Distributed denial of service**
  Traffic overwhelms online services, making them slow or inaccessible.
- **Payment and transaction fraud**
  Stolen credentials, fraudulent orders and chargeback abuse create losses.
- **Application and data attacks**
  Weak access controls, insecure APIs or vulnerable software expose records.



Phishing: how it affects online shoppers

Example: a fake delivery update directs a customer to a lookalike login page.

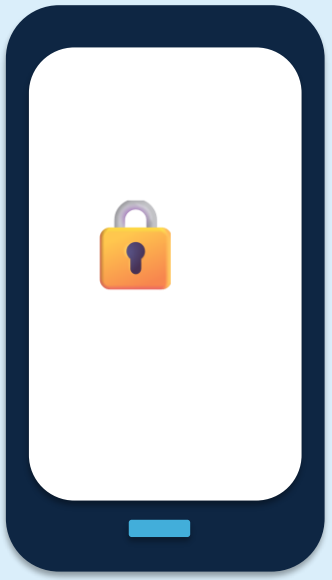
- **Typical warning signs**

  Unexpected urgency, suspicious sender, unusual URL or request for passwords/OTP.
- **Business consequences**

  Account compromise, fraudulent orders and customer mistrust.
- **Customer safeguards**

  Navigate using trusted bookmarks/apps; verify the domain and contact support.
- **Merchant safeguards**

  Use MFA, verified communication channels, awareness training and monitoring.

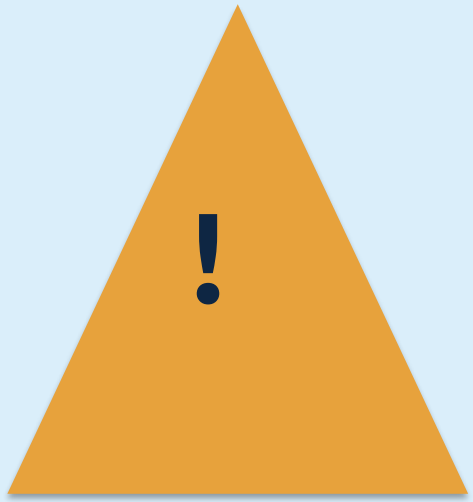


CUSTOMER DEVICE

Phishing case: suspicious order message

Class discussion: Which signals suggest this message may be fraudulent?

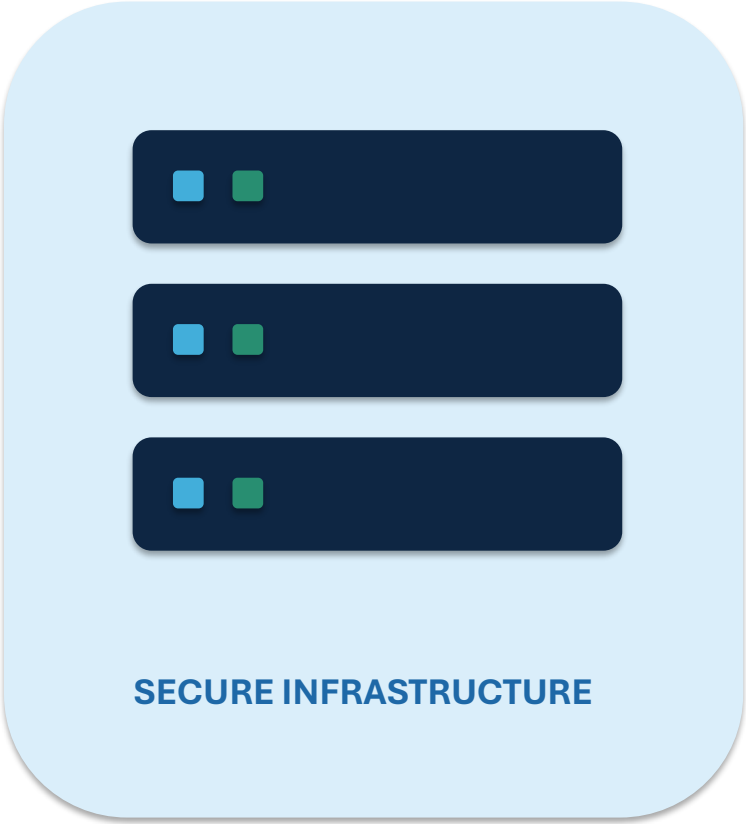
- **Scenario**
  A customer receives “Your order is blocked—verify your payment now.”
- **Red flags**
  Unexpected request, urgency, unfamiliar domain and sensitive-data collection.
- **Safe response**
  Avoid the message link; open the store directly and check order status.
- **Business response**
  Provide reporting channels, warn affected users and investigate impersonation.



DDoS: availability under pressure

A denial-of-service event targets access rather than necessarily stealing data.

- **What happens**
  Large volumes of requests exhaust network, server or application capacity.
- **E-commerce impact**
  Search, checkout and payment sessions may fail during peak sales.
- **Defensive layers**
  CDN, DDoS protection, rate limiting, caching and resilient hosting.
- **Response readiness**
  Monitor traffic anomalies; coordinate with hosting/CDN providers.



Fraud in e-commerce

Fraud controls should protect both buyers and legitimate merchants.

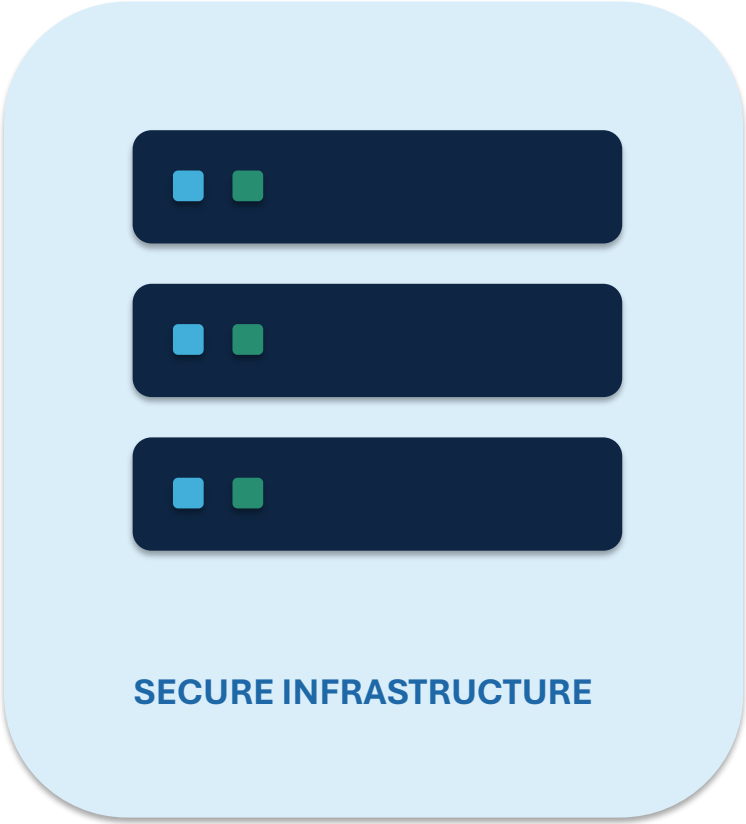
- **Account takeover**
  Attackers use compromised credentials to access customer accounts.
- **Card-not-present fraud**
  Unauthorized payment details are used for online purchases.
- **Refund and return abuse**
  Manipulated refund claims can cause financial loss.
- **Risk controls**
  Multi Factor Authentication, payment-provider risk checks, transaction alerts and manual review.



Other important threats

A secure checkout depends on the entire application ecosystem.

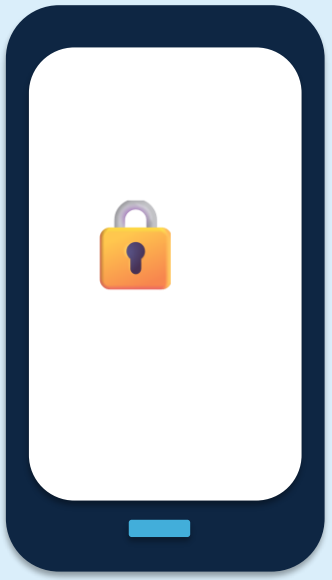
- **Insecure access control**
  A user might see another customer’s order if authorization is weak.
- **Injection and unsafe input**
  Untrusted input can affect backend queries or commands.
- **Malicious third-party scripts**
  Checkout scripts can threaten payment-page integrity.
- **Unpatched software and secrets**
  Outdated components and exposed credentials increase breach risk.



Client-side security measures

Controls on the customer device and in the browser.

- **Secure connections**
  HTTPS/TLS protects information while it travels over networks.
- **Safe authentication**
  Use strong unique passwords, MFA and secure session handling.
- **Browser/application hygiene**
  Keep browsers and mobile apps updated; minimize risky extensions.
- **Safe user behavior**
  Verify website addresses and avoid entering credentials through unexpected links.

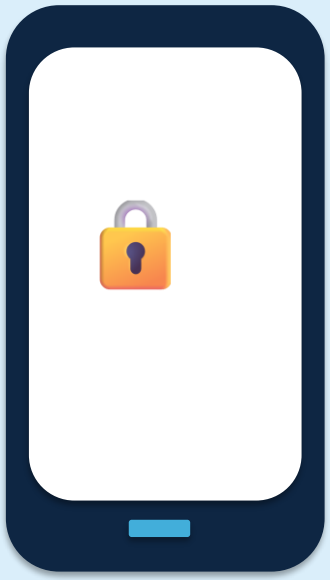


CUSTOMER DEVICE

Browser-side security in web design

Developers must assume browser content and user input can be manipulated.

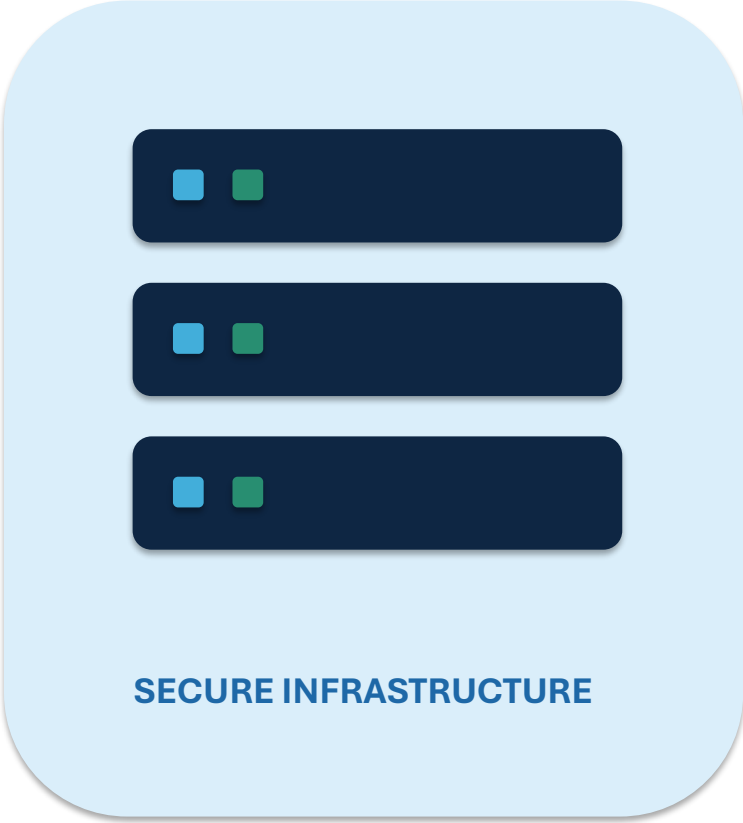
- **Content Security Policy (CSP)**
  Restricts where scripts and other content can load from.
- **Secure cookies**
  Use Secure, HttpOnly and appropriate SameSite settings.
- **Input/output handling**
  Validate input on the server and encode untrusted content when displayed.
- **Payment-page protection**
  Inventory and monitor scripts that can affect checkout.



Server-side security measures

The server must enforce security even when client-side checks fail.

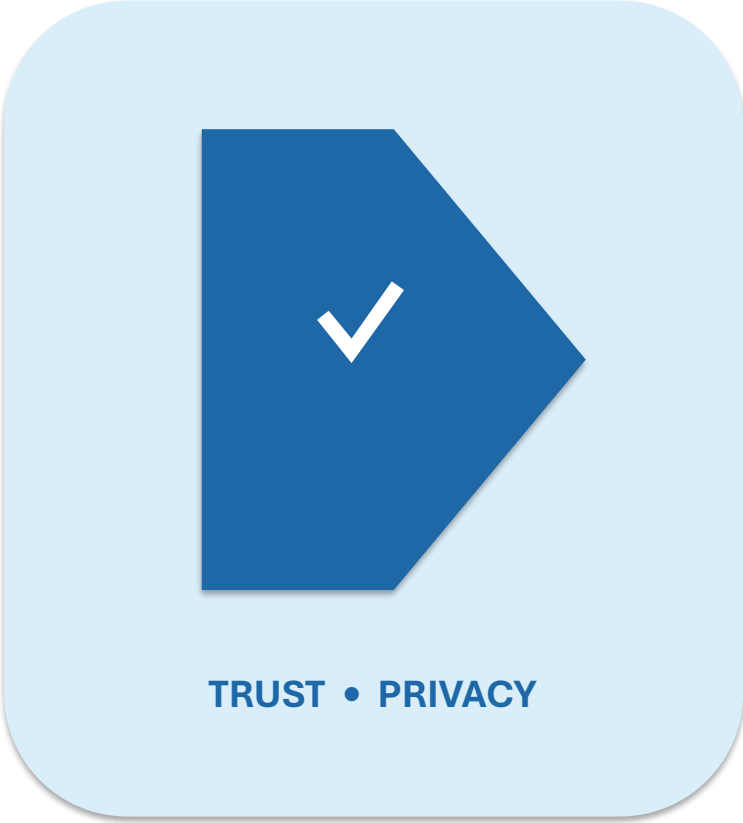
- **Identity and access**
  Use server-side authorization, least privilege and MFA for administrators.
- **Application security**
  Validate inputs, use parameterized database queries and protect APIs.
- **Infrastructure security**
  Patch systems, isolate services, protect secrets and encrypt sensitive data.
- **Operations**
  Centralized logging, monitoring, backups and tested incident-response plans.



Client-side vs server-side: comparison

Both are necessary; neither can replace the other.

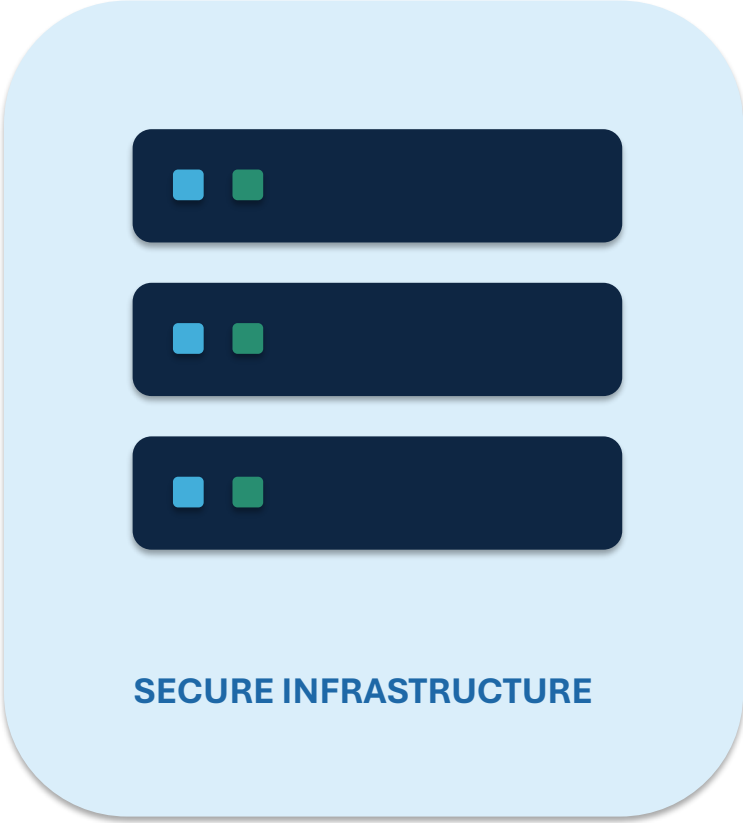
- **Client-side focus**
  Protect the user interaction, browser execution and session experience.
- **Server-side focus**
  Enforce permissions, business rules, data access and transaction integrity.
- **Example: price tampering**
  A browser may display a total, but the server must recalculate it.
- **Design principle**
  Apply defence in depth across customer, application, network and operations.



Secure checkout architecture

Illustrative flow for a safer online purchase.

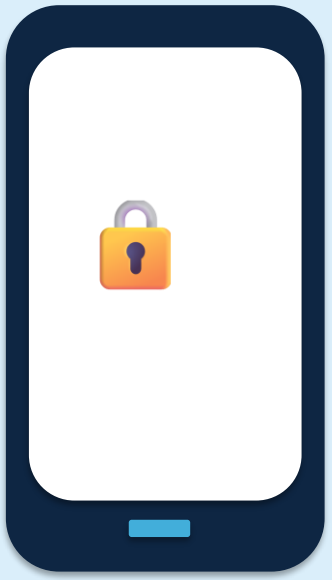
- **1. Customer and browser**
  Customer signs in securely and sends order details over HTTPS.
- **2. E-commerce backend**
  Server validates cart, calculates totals and creates a payment request.
- **3. Payment service provider**
  Use an appropriate hosted/outsourced payment flow where possible.
- **4. Confirmation and records**
  Verify provider responses server-side and update the order securely.



Security controls across the customer journey

Consider safeguards at each step of a real shopping session.

- **Registration and login**
  MFA, account recovery controls and login anomaly detection.
- **Product browsing and cart**
  Secure APIs, correct access control and trusted price calculations.
- **Checkout and payment**
  HTTPS, payment-provider integration and transaction monitoring.
- **After-sales and support**
  Protected customer records, verified refunds and restricted staff access.



CUSTOMER DEVICE

What is a cybersecurity framework?

A **cybersecurity framework** is a **structured set of guidelines, best practices, standards, and processes** that helps an organization identify and manage cybersecurity risks and protect its information systems, networks, applications, and data.

- **Business value**

  Connect security investments to organizational risk and objectives.

- **Examples**

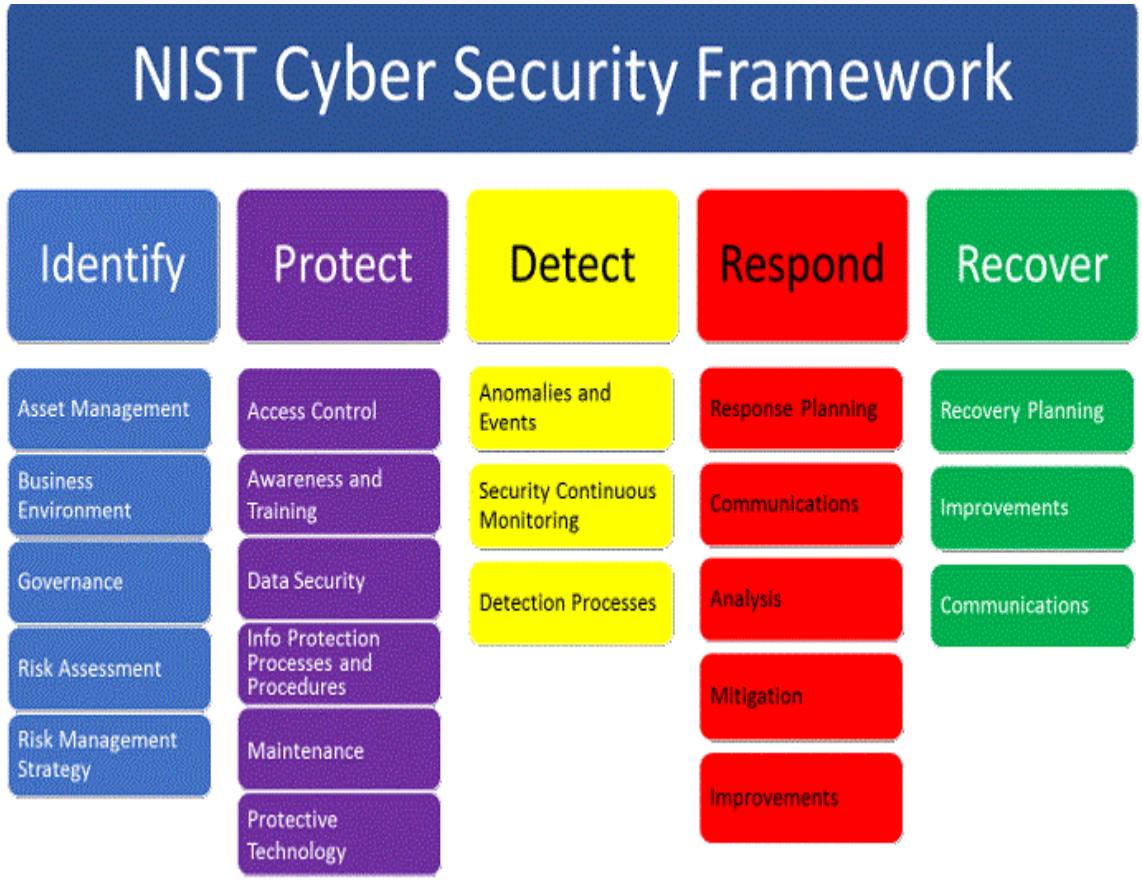
  NIST CSF 2.0, ISO/IEC 27001 and payment-specific PCI DSS.



NIST Cybersecurity Framework 2.0

Six functions support continuous risk management.

- **GOVERN + IDENTIFY**
  Set risk policy and responsibilities; understand assets and exposure
- **PROTECT**
  Use safeguards such as MFA, access control, secure configurations.
- **DETECT + RESPOND**
  Recognize suspicious activity and manage incidents effectively.
- **RECOVER**
  Restore services and learn from failures to improve resilience.



Applying NIST CSF to an online store

NIST Function	Main Objective	Application to ABC Online Store
1. Govern	Establish cybersecurity strategy and policies.	Define security policies, responsibilities, and legal obligations.
2. Identify	Understand assets and cybersecurity risks.	Identify customer databases, payment systems, threats, and vulnerabilities.
3. Protect	Implement safeguards against threats.	Use MFA, HTTPS, access controls, encryption, and security updates.
4. Detect	Identify suspicious activities.	Monitor unusual traffic, login attempts, and payment transactions.
5. Respond	Manage and contain incidents.	Investigate incidents, restrict compromised accounts, and notify stakeholders.
6. Recover	Restore services and improve resilience.	Restore systems, verify security, resume operations, and improve controls.

ISO/IEC 27001 and PCI DSS

- **ISO/IEC 27001**

  This is an international standard for establishing, implementing, maintaining, and continually improving an **Information Security Management System (ISMS)**.
  An **ISMS** is a structured approach that helps an organization manage information-security risks and protect important information.

- **PCI DSS**

  PCI DSS helps organizations protect payment information such as cardholder data by requiring appropriate technical and organizational security controls.

  Example: When a customer purchases a product from an online store using a credit or debit card, PCI DSS helps ensure that the systems involved in handling that card information are appropriately secured.

Personal data in an online store

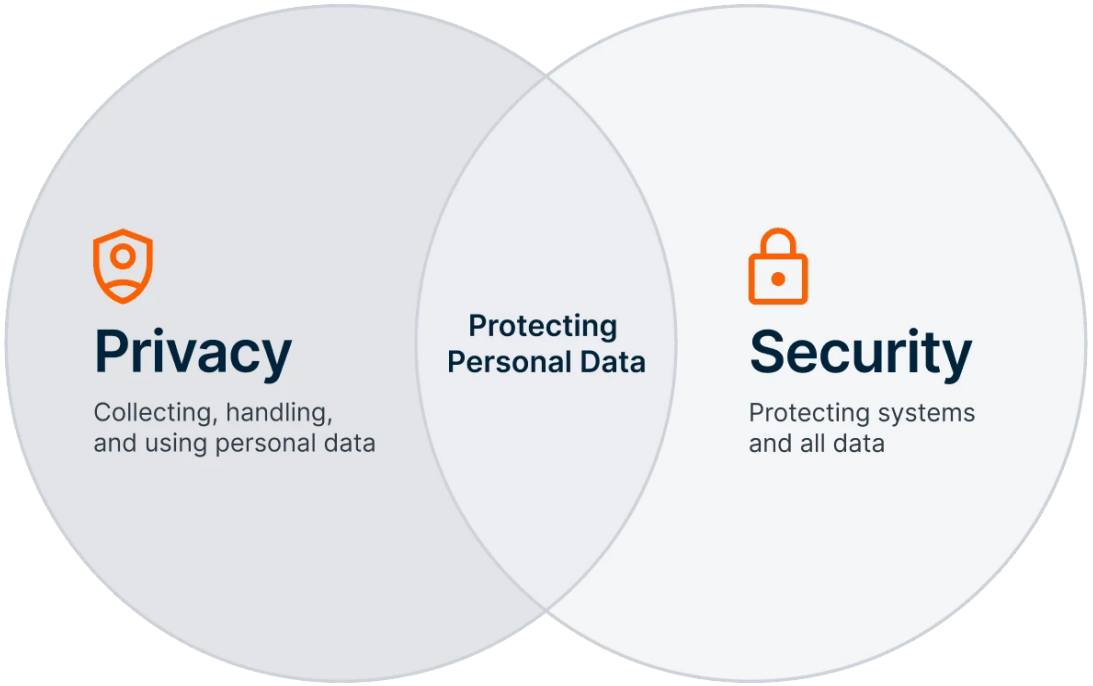
A business may collect far more than names and email addresses.

- **Identity and contact**
  Name, address, telephone, email and account identifiers.
- **Transaction and behavior**
  Orders, browsing activity, preferences and support interactions.
- **Data lifecycle**
  Collect → use → store → share → retain → delete.
- **Risk questions**
  Why is each field needed? Who can access it? When should it be removed?

Privacy and data-protection principles

Good data handling is both a legal and a design concern.

- **Transparency and lawful purpose**
  Tell people what data is collected and why it is processed.
- **Data minimization**
  Collect only information necessary for a defined business purpose.
- **Security and retention**
  Protect records and avoid keeping them longer than needed.
- **Individual rights and accountability**
  Enable applicable rights and document compliance decisions.



Sri Lankan legal context

- **Personal Data Protection Act**
  Sri Lanka’s PDPA No. 9 of 2022 is the core data-protection law.
- **2025 amendment**
  Personal Data Protection (Amendment) Act No. 22 of 2025 modified the principal Act.
- **Regulatory guidance**
  Check the Data Protection Authority for commencement notices and guidance.
- **Other relevant areas**
  Electronic transactions, computer crime and consumer protection may also matter.

Global legal context: GDPR and beyond

International online sellers may face obligations in several jurisdictions.

- **EU General Data Protection Regulation**
  GDPR governs covered personal-data processing, including some non-EU businesses.
- **Core principles**
  Lawfulness, fairness, transparency, purpose limitation and minimization.
- **Operational obligations**
  Privacy notices, security, lawful processing and applicable data-subject rights.
- **Cross-border caution**
  Jurisdiction and transfer rules depend on business activity and data flows.



Privacy by design: practical example

Example: creating a checkout form for a Sri Lankan online retailer.

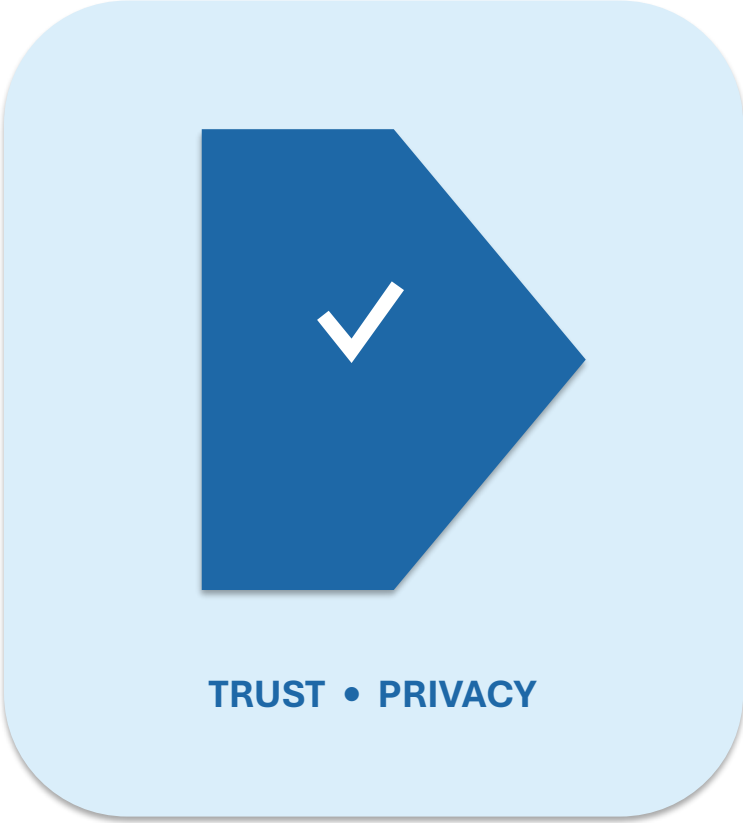
- **Before collecting data**
  Specify why each customer field is necessary for the order.
- **During processing**
  Limit staff access; use secure payment services and HTTPS.
- **After fulfilment**
  Apply retention rules; support correction/deletion requests when applicable.
- **When using third parties**
  Review contracts, data sharing, security and relevant transfer requirements.



Legal compliance checklist for an online store

Illustrative governance checklist—not a substitute for legal advice.

- **Customer-facing documents**
  Clear privacy notice, terms, refund/return and contact information.
- **Data handling**
  Lawful purposes, access controls, retention, breach procedures and vendor review.
- **Payment and consumer safeguards**
  Secure checkout, accurate pricing, transparent charges and dispute processes.
- **Ongoing governance**
  Track legal updates, train staff and document accountability.



Mini case study: a local marketplace

Apply security and privacy thinking to a familiar business scenario.

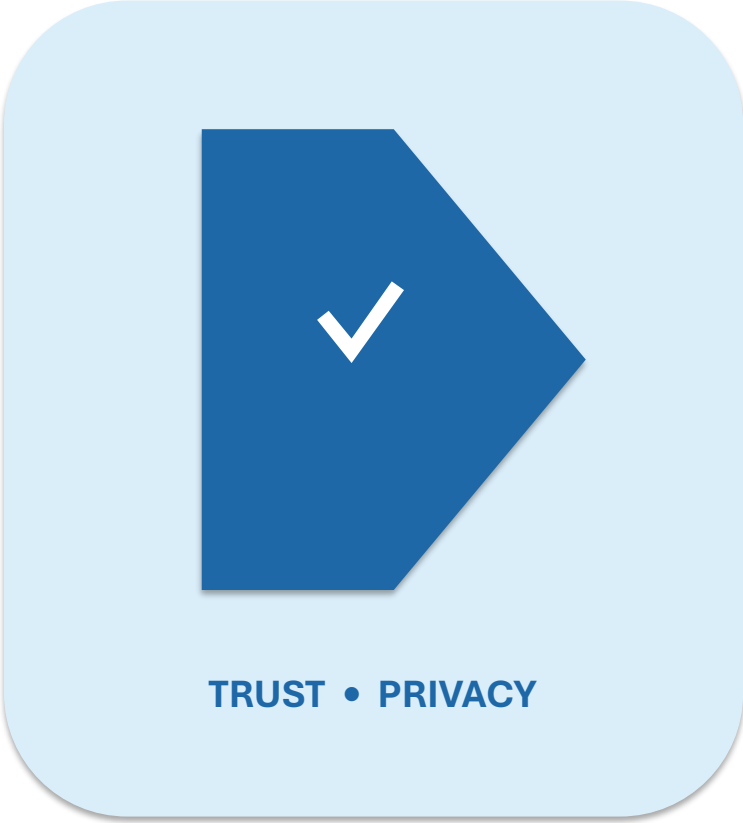
- **Scenario**
  A marketplace stores customer addresses and connects to a payment gateway.
- **Incident**
  Shoppers report fake delivery messages; checkout slows during a sale.
- **Group task**
  Identify assets, threats, likely impacts and suitable controls.
- **Discussion**
  Which controls are technical, organizational, customer-side or legal?



Key takeaways

Secure e-business requires coordinated technical and organizational decisions.

- **Risk awareness**
  Phishing, DDoS, fraud and application weaknesses threaten trust.
- **Defence in depth**
  Protect browsers, applications, servers, people and suppliers.
- **Frameworks**
  NIST CSF, ISO/IEC 27001 and PCI DSS organize different responsibilities.
- **Compliance**
  Privacy, security and legal requirements must be considered throughout design.



References & further reading

Official primary sources for further study and regulatory verification.

NIST Cybersecurity Framework 2.0	https://www.nist.gov/cyberframework
Sri Lanka Data Protection Authority	https://www.dpa.gov.lk/
Personal Data Protection (Amendment) Act 2025	https://www.dpa.gov.lk/acts/22-2025_E_251104_201549.pdf
European Commission: GDPR principles	https://commission.europa.eu/law/law-topic/data-protection/
PCI Security Standards Council	https://www.pcisecuritystandards.org/
OWASP Web Security guidance	https://owasp.org/

Thank You...